ملحق تفاصيل متطلبات الامن السيبراني:

1. The Vendor should confirm full understanding, consideration, compliance, and readiness for Infrastructure Requirements listed in this document.
2. The Vendor must respond to each point, and provide applicable details and best practice for the following:
   - Compliance level (Fully Compliant, Partial Compliant, or Non-Compliant).
   - Description and clarification for how the requirements will be covered, and/or understanding of it, based on MHRSD's Infrastructure Requirements Check List for document, and Reference from provided Proposal, for all points mentioned in Document.
   - For any Partial Compliant or Non-Compliant, vendor should provide detailed explanation for the alternatives or the work around solutions for the required controls.

Security Compliance Requirements
Version: 2.0 Updated On: Oct 2025

In order to ensure provided Products / Solution meet minimum criteria during evaluation, this set of Infrastructure Requirements should to be verified during the procurement and proposals submission process.
Compliance should be in C1 (Full Compliance), C2 (Partial Compliance with justification), C3 (Non-Compliance).

Vendor Name: XXXXXX	Contract-ID: XXXXXX

	MHRSD's Cybersecurity Requirements	Compliancy			Comments
		C1	C2	C3	
General Requirements	Security Assessment shall be conducted before publishing any services.				
	Shall comply with Saudi Government regulations.				
	Non-disclosure agreement shall be signed by parties				
	High Level Design (HLD) and Low-Level Design (LLD) shall be provided to be reviewed and approved by HRSD information Security General Department prior the implementation.				

Governance	Each Platform shall be evaluated prior the start of any new project to verify its classification, based on the NCA classification for critical systems.				
	Shall comply with Essential Cybersecurity Controls (ECC) by Saudi National Cybersecurity Authority.				
	Shall comply with Critical Systems Cybersecurity Controls (CSCC) by Saudi National Cybersecurity Authority.				
	Shall comply with Cloud Cybersecurity Controls by Saudi National Cybersecurity Authority.				
	Shall comply with DCC, OSMACC, and TCC by Saudi National Cybersecurity Authority.				
	Shall comply with SADIA regulations.				
Architecture	The solution shall apply Separation of N-Tier Application Architecture which consist of: Client Tier (GUI Tier, Webpage). Presentation Tier (Service Layer, UI) Business Object Tier (Middle Tier, Data Validations) Data Access Tier (Connection Management, Session Management, Data Access classes). Database Tier.				
	Apply OAuth2 Standard for Application Authorization.				
	Apply OpenID Connect Standard for Authentications.				
	Apply Multi-Factor Authentication for login in.				
	Database shall be encrypted and masked for any transaction.				
	Enable application Logs, Timestamps, and X-Forwarding.				
	Follow Top 10 OWASP.				
	Application shall not allow password recycling. The number of password generations to be stored shall be parameterized function.				
	All traffic to, from and within the application must be encrypted in accordance with the latest encryption standards.				
	Personally Identifiable Information (PII) must be rendered unreadable				
Cloud	Cloud hosting shall be in Saudi Arabia.				
	Comply with Cloud Cybersecurity Controls by Saudi National Cybersecurity Authority.				
	OWSAP API security shall be applied.				
Operations	Management access shall be through controlled device approved from HRSD				
	All security controls shall be implemented on the level of the server.				
	Admin privileges shall be approved by Information Security General Department.				
Development	All application developments shall be done in the development environment only.				
	Follow best practices of Secure coding (OWSAP).				

	All application component shall be segregated in different servers and zones with applying N-Tier Architectures.				
	All development shall not use any real nor production data.				
	Developers shall not clone any production data for any new developments.				
	Access to Production Environment for new developments purposes shall be done on premise.				
	Prevent HTTP caching.				
Integration	All integrations shall be approved by HRSD Information Security general department.				
	Published application shall not have a direct access/integration with a database and shall be through a middleware.				
	Apply ReadyAPI or equivalent, however approval shall be obtained by HRSD security general department for proposed integration method.				
	All security controls shall be integrated.				
	All Logs shall be shared with Information Security operation center (SIEM).				
Audit	Information Security Team shall be able to Check and Evaluate as well as to conduct risk Assessment at any point.				